

Solomon Mwaura

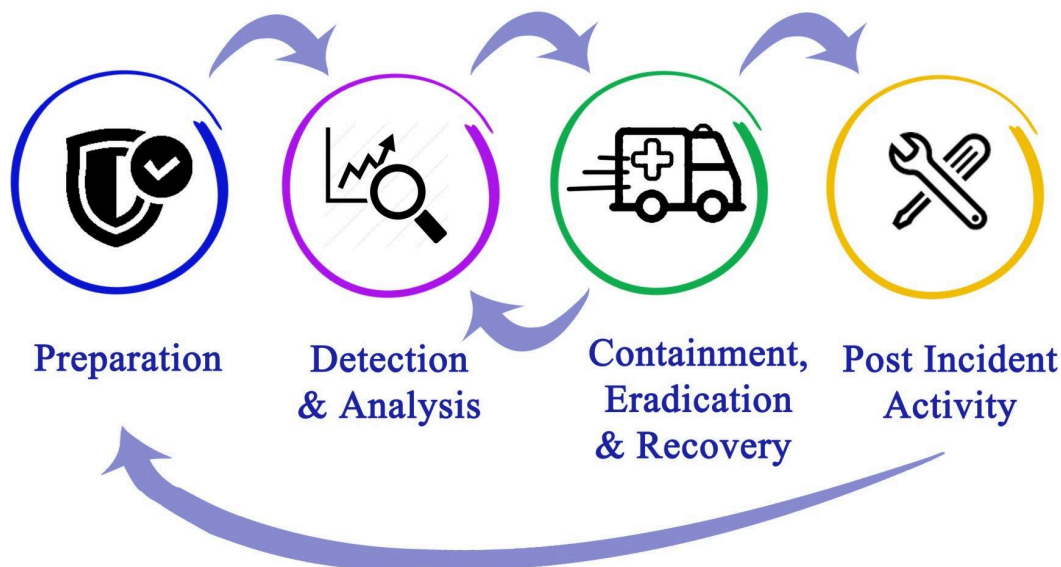
Incident Response Lab Report: BrightTech Solutions

Preparation

Objective: Evaluate the organization's preparedness for the incident and identify any gaps.

- **Current Roles, Responsibilities, and Tools:**
 - **Strengths:** BrightTech has a foundational Incident Response (IR) team with defined baseline roles (Incident Manager, Network Engineer, System Administrator, Communications Specialist). They also possess essential tools: NIDS, an Endpoint Protection Platform (EPP), nightly backups, and a Secure Web Gateway. The policy to isolate systems immediately and notify stakeholders within 24 hours is a strong baseline.
 - **Weaknesses/Missing Elements:** The IR team lacks dedicated security personnel, such as a Security Analyst, Threat Hunter, or Digital Forensics Expert. The toolset is missing advanced visibility tools like a Security Information and Event Management (SIEM) system or Endpoint Detection and Response (EDR); EPP often only prevents known signatures rather than detecting behavioral anomalies.
- **Insufficiencies in the IR Plan:** The most glaring gap is the lack of advanced incident response simulations. While basic phishing awareness exists, the team has not practiced handling a live, complex APT breach.
- **Actionable Suggestions:** * Upgrade the EPP to an EDR solution to gain deeper visibility into endpoint behavior.
 - Implement Data Loss Prevention (DLP) tools to monitor and block unauthorized outbound data transfers.
 - Incorporate specialized security roles or retain a third-party digital forensics and incident response (DFIR) firm on a retainer.

Incident Response Planning



Getty Images

Detection and Identification

Objective: Identify indicators of compromise (IoCs) and analyze logs or alerts to define the scope and severity of the incident.

- **Indicators of Compromise (IoCs):**
 - Large volumes of outbound data traffic during non-business hours.
 - NIDS alerts flagging connections to an external IP address linked to a known APT group.
 - Missing files and unauthorized file versions (modifications) on shared network drives.
- **Log/Alert Analysis:** Logs show that the malicious activity correlates directly with a spear-phishing campaign that began three days ago. The NIDS successfully caught the beaconing/exfiltration to the APT's infrastructure, but the 3-day dwell time indicates the initial payload bypassed the EPP.
- **Incident Scope and Severity: High/Critical.** The attack targeted financial and proprietary documents across multiple departments. The threat actor successfully achieved both data exfiltration (outbound traffic) and data sabotage (modified/missing files).

Containment

Objective: Propose short-term and long-term containment strategies to prevent the threat from spreading or recurring.

- **Short-Term Actions:**
 - Immediately disconnect all identified compromised endpoints from the network (keeping them powered on for memory forensics).
 - Block the flagged APT IP address and any associated domains at the firewall and Secure Web Gateway.
 - Force a mandatory password reset for all users, immediately disabling the accounts of users known to have interacted with the phishing email.
- **Long-Term Strategies:**
 - Implement strict network segmentation to separate the financial/proprietary data servers from general employee workstations.
 - Apply Geo-IP blocking for outbound traffic to regions where the company has no business operations.
 - Enforce Multi-Factor Authentication (MFA) across all internal systems and VPNs to prevent stolen credentials from being reused.

Eradication

Objective: Identify the root cause and remove malicious elements from the environment.

- **Root Cause Analysis:** The incident originated from a targeted spear-phishing campaign. Employees were deceived into clicking a malicious link or downloading an attachment. Because the EPP failed to stop the initial execution, the APT group gained a foothold, harvested credentials, escalated privileges to access shared drives, and set up a persistent connection to their external IP to exfiltrate data.
- **Eradication Steps:**
 - Wipe and reimage all compromised endpoints to ensure no persistent backdoors remain.
 - Remove any unauthorized files, scripts, or scheduled tasks dropped by the threat actors on the shared drives.
 - Patch and update all software on workstations and servers to close any vulnerabilities the attackers may have exploited for lateral movement.

Recovery

Objective: Restore systems to normal operation and ensure they are secure.

- **Restoration Process:** Utilize the nightly automated backup system to restore the missing and altered financial and proprietary documents to their state from four days ago (prior to the 3-day attack window).
- **Verification Steps:** Before reconnecting restored systems to the network, run deep offline anti-malware scans. Verify the integrity of the restored files by comparing file hashes with known good backup logs.
- **Post-Recovery Monitoring:** Place the affected departments on heightened monitoring. Set up customized NIDS alerts for any off-hours outbound traffic and monitor Active Directory logs for anomalous login attempts.

Post-Incident Review

Objective: Analyze the response process and identify lessons learned.

- **What Worked Well:** The NIDS successfully identified the malicious IP, and the nightly automated backups proved critical in ensuring data was not permanently lost. The policy of isolating systems immediately helped stop further exfiltration.
- **Areas for Improvement:** The 3-day delay in detection allowed the APT to steal and modify sensitive data. Standard phishing training failed to prevent the initial compromise.
- **Updated IR Plan Recommendations:** Update the IR plan to include specific playbooks for Data Exfiltration and Ransomware/Data Destruction. Establish a stricter Service Level Agreement (SLA) for log review and alert triage to reduce attacker dwell time.

Continuous Improvement

Objective: Propose long-term strategies for refining the incident response process.

- **Process Refinements:** Institute quarterly IR tabletop exercises simulating complex APT attacks and data exfiltration scenarios to build muscle memory within the response team.
- **New Security Measures:** Implement a SIEM system to aggregate logs from the EPP, NIDS, and firewalls for correlated, real-time alerting. Deploy DLP solutions specifically tuned to alert on bulk transfers of financial data.
- **Training Recommendations:** Standard phishing awareness is insufficient. Implement aggressive, customized spear-phishing simulations. Offer role-based security training (e.g., teaching System Administrators how to spot privilege escalation).

Conclusion

Objective: Summarize the incident response process and your key findings.

- **Summary of Actions Taken:** The incident team isolated affected systems, blocked the APT's external IP, enforced credential resets, eradicated the threat by reimaging endpoints, and successfully restored compromised financial data using nightly backups.

- **Key Recommendations:** BrightTech must transition from a reactive, prevention-only mindset to a proactive detection mindset by implementing EDR, SIEM, and DLP technologies, backed by routine, advanced IR simulations.
- **Assessment of Potential Impact:** The impact on BrightTech is severe. While the data was recovered, the exfiltration of proprietary and financial documents compromises the firm's competitive advantage. It may also trigger regulatory disclosure requirements, legal liabilities, and significant reputational damage among their consulting clients.